SECCIÓN 7.4

Automatización, SOAR y SOCless

Temas de esta sección:

- Diferencia entre automatización, orquestación y respuesta
- Qué es SOAR y qué es un playbook: flujo repetible para un tipo de alerta
- Ejemplo de playbook SOAR para Suspicious PowerShell
- Qué es SOCless y cómo funciona un flujo event-driven
- Qué acciones son automatizables, cuáles requieren aprobación y cuáles no
- Ejercicio: ¿automatizarías esta acción?

AUTOMATIZACIÓN

Ejecuta tareas repetitivas sin intervención manual.

Ejemplos:
- Consultar reputación de hash
- Buscar IOC en todos los endpoints
- Enriquecer dominio con TI
- Abrir ticket con evidencia

ORQUESTACIÓN

Conecta herramientas y equipos en un flujo.

Ejemplo:
EDR → TI → SIEM → ITSM → Teams → aprobación → acción

Permite que los sistemas hablen entre sí sin intervención manual en cada paso.

RESPUESTA

Ejecuta o recomienda acciones para reducir riesgo.

Ejemplos:
- Aislar endpoint
- Bloquear dominio
- Revocar sesión
- Aplicar regla WAF

Requiere aprobación humana en acciones de impacto.

7.4 | Ejemplo de playbook SOAR: Suspicious PowerShell

Un playbook es un flujo repetible para tratar un tipo de alerta. El paso 6 es crítico:

```
Trigger: Suspicious PowerShell

1. Obtener process tree desde EDR
2. Extraer hash, dominio e IP
3. Consultar threat intelligence
4. Buscar hash en otros hosts
5. Crear ticket con evidencia
6. Si score alto + acción Allowed:
   → pedir APROBACIÓN de aislamiento
7. Notificar a IR por Teams
8. Registrar todas las acciones
```

Puntos clave:

- El playbook acelera tareas repetitivas
- No reemplaza la validación de contexto
- Puede incluir gates de aprobación humana
- Debe registrar qué hizo y cuándo
- Debe tener manejo de errores y excepciones

El paso 6 es crítico: 'Si score alto + acción Allowed → pedir aprobación'. La automatización no aisla el endpoint sola. Pide aprobación humana, que es lo correcto.

7.4 | ¿Qué es SOCless?

DEFINICIÓN SIMPLE

SOCless es un enfoque donde tareas de operación de seguridad se ejecutan con funciones serverless, integraciones y flujos event-driven.

No depende solo de una consola SOC tradicional.

CÓMO FUNCIONA

Un evento dispara una función.

La función consulta fuentes, enriquece, decide una ruta, abre ticket, notifica o ejecuta una acción predefinida.

Todo queda trazado.

Cada paso se activa por eventos.

PARA QUÉ SIRVE

- Reduce tareas manuales
- Escala mejor que un SOAR monolítico
- Baja costos operativos
- Permite flujos más flexibles

No elimina la necesidad de criterio humano en decisiones de impacto.

7.4 | Flujo SOCless: ejemplo event-driven

Ejemplo simple de flujo SOCless para un IOC recibido por threat intelligence:

```
Event: New malicious domain

Function 1: validar formato y fuente
Function 2: buscar dominio en DNS/proxy
Function 3: identificar hosts afectados
Function 4: consultar criticidad de activos
Function 5: abrir ticket con evidencia
Function 6: si hosts críticos → notificar IR
Function 7: pedir APROBACIÓN para bloqueo
Function 8: registrar decisión y resultados
```

Idea clave:

- La lógica vive en funciones pequeñas
- Cada paso se activa por eventos
- Se integra con varias herramientas
- Permite automatizar sin depender de un SOC monolítico
- Debe incluir control humano en acciones sensibles

La Function 7 es clave: el bloqueo requiere aprobación. Un IOC nuevo sin validación podría ser un falso positivo o afectar servicios legítimos.

7.4 | Ejercicio: ¿automatizarías esta acción?

Clasificá cada acción como: Automatizable, Requiere aprobación o No automatizar sin revisión:

1. Consultar reputación de hash	AUTO	2. Buscar IOC en todos los endpoints	AUTO
3. Abrir ticket con evidencia	AUTO	4. Aislar endpoint de usuario	APROBACIÓN
5. Aislar servidor productivo	NO AUTOMATIZAR	6. Bloquear dominio dedicado malicioso	APROBACIÓN
7. Bloquear github.com globalmente	NO AUTOMATIZAR	8. Revocar sesiones de cuenta ejecutiva	APROBACIÓN
9. Generar resumen del caso	AUTO	10. Eliminar archivo sospechoso	APROBACIÓN

Los ítems 5 y 7 son errores claros. Bloquear github.com globalmente puede romper pipelines de desarrollo de toda la organización.